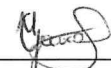




INFORMATION SECURITY AND DATA PROTECTION POLICY

VERSION 1.0

	Name	Designation	Signature	Date
Policy Originator	Tersia //Gowases	Executive: IT & Data Processing		15/8/2022
Company Approval	Alex Shimuafeni	Statistician-General		15/08/2022
Committee Approval	Damoline Mupoko	Chairperson of the Strategy and Board Affairs Committee		17/8/22
Board Approval	Salmon Hei	Chairperson of the Board of Directors		16/08/22

Document Change Control

Changes	Date	Chairperson of the Finance and Audit Committee	Chairperson of the Board of Directors

TABLE OF CONTENTS

1. POLICY.....	4
2. ORGANIZATION OF INFORMATION SECURITY	7
3. MOBILE DEVICES.....	7
4. TELEWORKING / WORKING FROM HOME	7
5. HUMAN RESOURCES.....	8
6. ASSET MANAGEMENT	9
7. ACCESS CONTROL	11
8. SYSTEM AND APPLICATION ACCESS CONTROL.....	14
9. CRYPTOGRAPHY.....	15
10. PHYSICAL AND ENVIRONMENTAL SECURITY	15
11. OPERATIONS SECURITY.....	17
12. COMMUNICATIONS SECURITY.....	20
13. SYSTEMS ACQUISITION, DEVELOPMENT AND MAINTENANCE.....	21
14. SUPPLIER RELATIONSHIP	22
15. INFORMATION SECURITY INCIDENT MANAGEMENT.....	22
16. INFORMATION SECURITY ASPECTS OF BUSINESS CONTINUITY MANAGEMENT	24
17. COMPLIANCE	25

DEFINITIONS

In the context of this policy the following terms mean

TERM	DESCRIPTION
Availability	Accessible and usable upon demand by an authorized entity/individual.
Asset	ICT assets
Baseline	A starting point or reference point.
Confidentiality	information is not made available or disclosed to unauthorized individuals, entities, or processes.
Control	A means of managing and safeguarding, or responsive measures to identified vulnerabilities.
Data	is data owned, processed or held by the NSA, whether primary or secondary, irrespective of storage location. It is used interchangeably with the term 'information'.
Encryption	Is a method by which information is converted into secret code that hides the information's true meaning.
Facilities	Geographical area / location where ICT infrastructure is located.
Framework	Structural representation to organise into groupings and categories.
Guideline	A recommendation of what is expected to be done to achieve an objective.
Incident	Single or series of events that have significance on the probability of compromising business operations and threatening information security.
Information Resource	An Information Resource is a discrete body of information created, collected, and stored in connection with the operation and management of the Namibia Statistics Agency and used by members of the Agency having authorized access as a primary source. Information Resources include electronic databases as well as physical files.
Integrity	Protecting the accuracy and completeness of organizational assets.
Malware	A program that is covertly inserted into another program with the intent to destroy data, run destructive or intrusive programs, or otherwise compromise the confidentiality, integrity, or availability of the victim's data, applications, or operating system.
Mobile Device	A portable electronic device that can be connected to the internet, including laptops, mobile phones, tablets, smart watches.
Privileged user	Are users that are granted administrative privileges to systems.
Procedure	A specified way to carry out an activity or a process.

Risk	A combination of the probability of an event and its consequence which pose threats to the Agency.
Security Breach	A Security Breach is any event that causes or is likely to cause Confidential Information to be accessed or used by an unauthorized person.
Threat	Potential cause of an unwanted incident, which may result in harm to a system or organization.
Vulnerability	The weakness of an asset or control that can be exploited by a threat.

1. POLICY

1.1 POLICY STATEMENT

This policy is the fundamental document that guides the management of information and data security at the Namibia Statistics Agency. This policy ensures that all ICT infrastructure as well as all information/data of which the NSA has authority over shall be appropriately secured to safeguard it against the consequences of breaches of confidentiality, failures of integrity or interruptions to the availability.

1.2 SCOPE

- 1.2.1 This policy is applicable to all NSA staff, including permanent and fixed contract employees, stakeholders, contractors, and consultants.
- 1.2.2 The policy is applicable to all the devices, networks and software owned, under the custodianship of the NSA or making use of the NSA's ICT infrastructure.
- 1.2.3 The policy applies to all the data over which NSA holds the rights, data over which the NSA is the data controller, data processor or custodian, as well as communications sent to or from the NSA including all personal data processed for the Agency's business or operations, regardless of where it is held and automatically processed data, or the ownership of the equipment used.

1.3 POLICY OBJECTIVES

The objectives are to:

- 1.3.1 Provide a framework for establishing suitable levels of information security and data protection for all NSA information systems (including but not limited to all computers, mobile devices, networking equipment, software, digital data, and data on hardcopies).
- 1.3.2 Establish controls to protect NSA's Data, information and information systems and mitigate the risks associated with the theft, loss, misuse, damage or abuse of these systems and equipment.
- 1.3.3 Provide a safe and secure information systems working environment for all authorized users.
- 1.3.4 Ensure that all users (e.g. employees, contractors, stakeholders) understand and are aware of their responsibilities towards protecting the confidentiality, integrity and availability of the data that they handle, including satisfying the information security requirements of third-party data providers.
- 1.3.5 Ensure that the NSA is capable of safeguarding all information, data and systems during major or minor security incidents or breaches.
- 1.3.6 Ensure flexibility and sufficient security for accessing information systems from regional offices and remote locations.

1.4 LEGISLATIVE & COMPLIANCE REQUIREMENTS

This Policy has been developed taking into account

- the Statistics Act of 2011,
- NSA ICT Governance Policy,
- NSA ICT Policy and Procedures,
- NSA Asset Management Policy
- Namibia Statistics Policy,
- Data Collection, Processing and Dissemination Policy,
- NSA Security policies,
- National Spatial Data Infrastructure Policy,
- International Organization for Standardization (ISO) 27001,
- and the COBIT 19 IT governance framework for information security.

1.5 KEY POLICY PRINCIPLES

- 1.5.1 It is the responsibility of any user of the NSA's ICT resources to offer their outmost active cooperation in ensuring that the information security and data protection policy is adhered too.
- 1.5.2 Each employee must be acquainted with the NSA's information security and data protection policy and adhere to the duties and responsibilities outlined in the policy
- 1.5.3 Each employee of NSA must also be formally obliged to respect these policies and other rules and procedures on information security and data protection that have been adopted by NSA.
- 1.5.4 The statement that must be signed by each person working at NSA or other kind of relationship or alliance is attached as Annexure 1 to this policy.
- 1.5.5 The Information Security Management is based on flexible development, improvement, and training of all the internal and external stakeholders and on increasing the general awareness of the importance of the information security and data protection at NSA.
- 1.5.6 Periodic training on information security will be carried out for the employees and it is adapted in a view of the risks that arise from the individual roles performed by the NSA employees and broader stakeholders.
- 1.5.7 An employee who violates or breaches this policy will be dealt with in terms of the NSA disciplinary policy and NSA code of conduct.
- 1.5.8 When deliberating on the breaches and selection of the sanction thereafter, the following must be considered:
 - a. mode of breaching the policy,
 - b. the seriousness of the breach,
 - c. number of breaches and other circumstances that are relevant for bringing the decision.

In case of serious breaches, NSA can use all the available legal means against those having committed a breach, including entering a criminal complaint in case of suspicion of committing a criminal offence or placing a claim.

1.6 DOCUMENTS ON INFORMATION SECURITY

This policy represents the basic document for the organization and management of information security and data protection at NSA. Subordinate documents that regulate individual procedures and measures related to the managing of information security and protection of data are adopted on the basis of this policy.

Table 1 Subordinate documents types

Document	Purpose
Rules (Policies)	To address pertinent issues, such as what constitutes acceptable behaviour by employees and stakeholders.

Operational procedures (Guidelines)	A defined sequence of steps to be followed in a consistent manner, such as how the organization will respond to any policy violations.
Instructions (Technical Standards)	It is a formal document that establishes uniform engineering or technical instructions, methods, processes, and practices.
Manuals	Provides instructions or guidelines on how to perform an activity and serves as a reference book on the activity.

1.7 RACI CHART RESPONSIBILITIES

The Responsible, Accountable, Consulted, and Informed (RACI) matrix describes roles and responsibilities of individuals responsible for completing specific tasks, business processes, milestone, or project.

The model defines the following roles:

- **Responsible:** Individual performs the task to completion.
- **Accountable:** Individual that is answerable for the correct completing of the work
- **Consulted:** Individuals are typically subject matter experts who are approached for their inputs.
- **Informed:** Individuals or team members that are to be kept up-to-date on the progress of specific tasks, business processes, milestone, or project.

Table 2 RACI Chart for information security and data protection at the NSA

Role	Responsibility
Board and Board Committees	Informed
Statistician General	Accountable
IT Steering Committee	Informed
Executive: IT & Data Processing	Responsible
Manager: IT	Responsible
Senior Information Security Officer	Responsible
Information Security Specialist	Responsible
Internal Audit	Informed
Chief of Security	Consulted
Stakeholders internal and external	Consulted
Staff	Informed

1.8 POLICY REVIEW

The policy should be regularly reviewed after every two (2) years or when deemed fit and updated in line with the national and Agency information security ecosystem at the

time and should be applied consistently and aligned with the wider NSA information security objectives.

2. ORGANIZATION OF INFORMATION SECURITY

- 2.1 Responsibilities for the protection of individual assets and for carrying out specific information security processes should be identified, defined and allocated to competent people.
- 2.2 Conflicting duties and areas of responsibility should be segregated to reduce opportunities for unauthorized or unintentional modification or misuse of the NSA's assets.
- 2.3 The Agency should have procedures in place that specify when and by whom authorities (e.g. law enforcement, regulatory bodies, and supervisory authorities) should be contacted and how identified information security incidents should be reported in a timely manner.
- 2.4 Information security should be integrated into the Agency's project management methods to ensure that information security risks are identified and addressed as part of the project.

3. MOBILE DEVICES

- 3.1 All Agency employees, contractors, stakeholders and any third party wishing to make use of the NSA's mobile device/s should familiarize themselves and abide by signing the Mobile Device Usage guideline.
- 3.2 An up-to-date asset register for all the Agency's mobile devices should be kept at all times, clearly indicating the location, condition, Asset tag, serial number, International Mobile Equipment Identity (IMEI), and the lessees/user's name if leased out.
- 3.3 The IT division must ensure that no Agency mobile devices are allocated or used without the appropriate physical protection (Screen protector, protective case etc.).
- 3.4 Anti-Malware software of the Agency's choice should be installed and updated on the mobile device before being leased or allocated to users.
- 3.5 Mobile Device Management software should be used to remotely disable, erase or lockout software/application/feature. This setting must be enabled on the tablet before it is issued out.
- 3.6 Updating of the tablet software version or firmware or installations of any updates must only be done by qualified and authorized IT professionals from the NSA only.
- 3.7 All non-Agency mobile devices to be connected or utilize the NSA's ICT infrastructure shall be configured and secured as per the established protocols in line with this policy.

4. TELEWORKING / WORKING FROM HOME

- 4.1 When working remotely, it is the duty of the employee, contractor or internal and external stakeholder to ensure that the working environment is safe and has appropriate access control mechanisms e.g. working doors with locks, and safe storage facilities etc.
- 4.2 Do not leave device/s unattended in a public place, i.e. vehicle, hotel or home.
- 4.3 Employees, contractors, or stakeholders must ensure that device/s are secured in a safe or other locked facility/room when the device is left unattended or not in use.
- 4.4 When making use of a vehicle, keep device/s out of sight. E.g. In the boot or storage compartment, provided that there is no risk from heat or physical damage when transporting.
- 4.5 When at home, keep device/s out of sight, away from windows and easily accessible areas.
- 4.6 If it is anticipated that the device is to be left unattended, it must be logged out or powered off in order to secure the device.
- 4.7 Ensure that other 'non' authorized users are not given access to the device/s, NSA networks and restricted or confidential data e.g. Family members, unauthorized colleagues, non-NSA

IT professional to work or undertake any repairs whatsoever without the authorization of the Manager: IT.

- 4.8 Employees, contractors or stakeholders should be extra vigilant when using devices in public areas and at home to avoid the unauthorized disclosure of Agency information by a third party overlooking content displayed on the screen.
- 4.9 Do not log into the Agency's information systems using public devices and untrusted networks. (E.g. trying to use VPN from a public Café's computer).
- 4.10 Employees, contractors and stakeholders wishing to utilize the Agency's VPN service should fill out the VPN access application form as well as read, understand and accept the terms and conditions of Remote Access Service (RAS) / VPN of the ICT Policy and Procedures.
- 4.11 If need be the Employees, contractor or stakeholder shall grant the Agency access to their privately-owned equipment in order to verify and setup the security provisions to securely access the Agency infrastructure.
- 4.12 Employee, contractor or stakeholder should return all equipment leased out for the purpose of Teleworking or working from home immediately after returning to the office as per the agreed usage period.

5 HUMAN RESOURCES

5.1 PRIOR TO EMPLOYMENT

- 5.1.1 Background verification checks on all candidates for employment should be carried out in accordance to relevant laws, regulations, and NSA policies and should be proportional to the Agency's requirements.
- 5.1.2 The contractual agreement with employees and contractors should state their responsibilities towards information security.
- 5.1.3 The contractual obligations for employees or contractors should reflect the Agency's policies for information security in addition to clarifying that
 - 5.1.3.1 All employees or contractors who are given access to the Agency's confidential information or data should sign a confidentiality or non-disclosure agreement prior to being given access to the information.
 - 5.1.3.2 Applicable actions are to be taken if the employee or contractor disregards the Agency's security requirements.

5.2 DURING EMPLOYMENT

- 5.2.1 All employees, contractors, stakeholders and authorized individuals or entities must apply information security in accordance with the established policies and procedures of the NSA.
- 5.2.2 It is the duty of the NSA to make sure that all employees, contractors and stakeholders are properly briefed on their information security roles and responsibilities prior to being granted access to confidential information or information systems.
- 5.2.3 All employees of the NSA and where relevant, contractors should receive appropriate awareness education and training and regular updates on the Agency's Information security policies and procedures as relevant to their job function.

- 5.2.4 All employees should read and abide to ICT Policy and Procedure and ICT Governance Policies to ensure awareness of acceptable usage of ICT technologies.
- 5.2.5 All employees should read and abide to by the Social Media Policy and to ensure acceptable usage of internet and social media platforms

5.3 TERMINATIONS OF EMPLOYMENT OR CONTRACTS

- 5.3.1 Employees, contractors and other authorized individuals or entities shall return all NSA assets in a satisfactory condition upon separation from employment, contract, or agreement.
- 5.3.2 The access rights of all employees, contractors and other authorized individuals or entities to information/data and information systems shall be removed or altered as appropriate upon separation or termination of their employment, contract, or agreement, or adjusted upon reassignment.
- 5.3.3 It is the duty of the Human Resources (HR) department to notify the IT department of any terminations of employment, promotions, or reassignments prior to the effective date in order for the IT team to modify the access controls and authorization accordingly.
- 5.3.4 Information security responsibilities and duties that remain valid after termination of employment, contract, or agreement, or, after reassignment should be defined, communicated to the employee, contractor or stakeholder and enforced.

6 ASSET MANAGEMENT

6.1 RESPONSIBILITY OF ASSETS

- 6.1.1 Assets associated with information and information processing facilities shall be identified and an inventory of these assets shall be drawn up and maintained on a regular basis, in line with the NSA Asset Management Policy.
- 6.1.2 The asset inventory should be accurate, up to date, consistent and aligned with other inventories of the agency.
- 6.1.3 Ownership should be assigned when an asset is created or when assets are transferred to the Agency's control. The Agency shall be responsible for the proper management of an asset over the asset's lifecycle.
- 6.1.4 The NSA should ensure that:
 - a. the assets are inventoried.
 - b. assets are appropriately classified and protected.
 - c. define and periodically review access restrictions and classifications to important assets, considering applicable access control policies, procedures and guidelines.
 - d. proper handling when the asset is deleted, destroyed or decommissioned from service.

- 6.1.5 Routine tasks may be delegated by the Agency, e.g. to a custodian looking after the assets on daily basis.
- 6.1.6 Rules for the acceptable use of information and assets associated with information and information processing facilities should be identified, documented and implemented.
- 6.1.7 All employees and external party users shall return all agency assets in their possession, be it physical or digital, upon termination of their employment, contract or agreement.
- 6.1.8 In cases where an employee or external party user purchases the Agency's equipment or uses their own personal equipment, procedures should be followed to ensure that all relevant information/data is transferred to the Agency and securely erased or destroyed from the equipment.

6.2 INFORMATION CLASSIFICATION

- 6.2.1 Information/data shall be classified in terms of legal requirements, value, criticality, and sensitivity to combat unauthorized disclosure or modification.
- 6.2.2 The classification levels used by the NSA must explicitly incorporate all data and information under the administration and control of the Agency; therefore, appropriate controls for securing information based on levels of classification should be applied on all Agency data and information every time.
- 6.2.3 Assets other than information must also be classified in conformance with classification of information which is stored in, processed by or otherwise handled or protected by the asset.
- 6.2.4 Information and data may change classification levels over its lifetime i.e. certain data or information may be classified as confidential prior to release, but become public after release.
- 6.2.5 Owners of information assets should be accountable for their classification and review of the asset's classification level over the asset's life cycle.
- 6.2.6 The NSA shall employ a 4 level classification scheme. The classification scheme should be consistent across the whole Agency so that everyone will classify information and related assets in the same way.

CLASSIFICATION LEVEL	IMPACT
CONFIDENTIAL	Disclosure has a serious impact on long term strategic objectives or puts the reputation of the Agency at risk
RESTRICTED	Disclosure has a significant short-term impact on operations or tactical objectives.
INTERNAL	Disclosure causes minor embarrassment or minor operational inconvenience.
PUBLIC	Disclosure causes no harm.

- 6.2.7 Procedures should be drawn up for handling, processing, storing and communicating information consistent with its classification.

6.3 REMOVABLE MEDIA HANDLING

- 6.3.1 If no longer required, the contents of any re-usable media that are to be removed from the NSA should be made unrecoverable.
- 6.3.2 Media must be disposed of securely when no longer required, using formal procedures.
- 6.3.3 Media containing information must be protected against unauthorized access, misuse or corruption during transportation using formal procedures.
- 6.3.4 Depending on the classification level of the data/information on the removable media, cryptographic techniques should be used to protect confidentiality and Integrity.
- 6.3.5 Where necessary and practical, authorization should be required for media removed from the NSA and a record of such removals should be kept in order to maintain an audit trail.
- 6.3.6 The use of removable media to transport data or information should only be allowed in special authorized cases.
- 6.3.7 Where there is a need to use removable media the transfer of information to such media should be monitored.
- 6.3.8 Only reliable transport or couriers should be used to transport media containing confidential and restricted data.
- 6.3.9 A documented chain of custody must be maintained, clearly identify the content of the media, times of transit and notice of receipt at the destination.
- 6.3.10 Media containing confidential information should be stored and disposed of securely.
- 6.3.11 Disposal of sensitive items should be logged in order to maintain an audit trail.

7 ACCESS CONTROL

7.1 DATA ACCESS CONTROL

- 7.1.1 Access to information/data assets as well as other information processing assets under the Agency's control is generally forbidden, unless expressly permitted in writing by the custodian of the data or the Statistician-General.
- 7.1.2 Need-to-know: Employees, contractors, stake holders or the public should only be granted access to the information they need to perform a task/job as permitted by NSA policies or the relevant Namibian Laws.
- 7.1.3 Need-to-use: Employees, contractors, stake holders or the public should only be granted access to the information processing facilities (IT equipment, applications, procedures, rooms) they need to perform a task/job/role as permitted by NSA policies or the relevant Namibian Laws.

- 7.1.4 Access to business information assets and activations of user accounts for contractors, consultants, and vendors will be provided only on the basis of a contractual agreement and approval by the statistician general.
- 7.1.5 The NSA should determine appropriate access control rules, access rights and restrictions for specific user roles towards their assets, with the amount of detail and strictness of the controls reflecting the associated information security risks.
- 7.1.6 Access rights shall be periodically reviewed by the NSA custodians of access rights provisioning.
- 7.1.7 Business application access controls should reflect the classification of the data or information stored or processed by the application and the criticality of that data or information to the Agency.
- 7.1.8 Access control roles shall be segregated. Access request and access authorization shall be handled by the IT division which is responsible for access control administration pending a formal access authorization process.

7.2 ACCESS TO NETWORKS AND NETWORK SERVICES

- 7.2.1 The NSA's information networks should be divided into logical segments based on the access requirements.
- 7.2.2 Users shall only be provided with access to the network and network services that they have been specifically authorized to use.
- 7.2.3 Access to NSA file servers is strictly restricted to Agency employees. Stakeholders, contractors and other third parties wishing to gain access to such services should be formally authorized by their executive/ line manager in writing to the Executive: IT & Data Processing .
- 7.2.4 Access to the various NSA networks is strictly restricted to NSA employees and NSA managed devices. Stakeholders, contractors and other third parties and privately-owned devices wishing to gain access to the network should formally be authorized by their executive/ line manager in writing to the Executive: IT & Data Processing .
- 7.2.5 VPN services are strictly restricted to NSA employees. Stakeholders, contractors and third parties wishing to make use of this service should be authorized by their executive/ line manager in writing to the Executive: IT & Data Processing .
- 7.2.6 Routing controls should be implemented for networks to ensure that computer connections and information flows do not breach the access control policy of the applications and devices.
- 7.2.7 The Agency reserves the rights to monitor access and use of all its network services.
- 7.2.8 Sensitive systems should have a dedicated (isolated) computing environment.
- 7.2.9 Physical and logical access to diagnostic and configuration ports should be controlled.

7.3 USER ACCESS MANAGEMENT

- 7.3.1 The registration and termination of users must be in accordance with the user registration and termination procedure.
- 7.3.2 All users of information resources must have a unique user ID/username and login credentials to access NSA's information assets.
- 7.3.3 Shared usernames/IDs and accounts should only be used when necessary for business or operational reasons and should be approved and documented.
- 7.3.4 User accounts for employees who have been transferred to different departments must be reviewed for access control and privilege compliance.
- 7.3.5 User accounts for terminated employees must be removed immediately after their termination.
- 7.3.6 Access rights should not be activated before authorization (obtained from the owner of asset) procedures are completed.
- 7.3.7 A formal record of all registered users must be maintained. This record must be checked periodically for unused, redundant, or expired user accesses or accounts.

7.4 MANAGEMENT OF PRIVILEGED ACCESS RIGHTS

- 7.4.1 All privileges to the users must be assigned through a formal authorization procedure and no privileges should be assigned before the completion of the authorization procedure.
- 7.4.2 All privilege access rights should be allocated to users on a need-to-use basis and on an event-by-event basis in line with the access control policy. I.e. based on the minimum requirement for their functional roles.
- 7.4.3 The competences of users with privileged access rights should be reviewed regularly in order to verify if they are in line with their duties.
- 7.4.4 Shared administrator account secret authentication information must be changed frequently and as soon as possible when a privileged user leaves or changes jobs, communicating them among privileged users with appropriate mechanisms.

7.5 SECRET AUTHENTICATION MANAGEMENT

- 7.5.1 Users should read, and abide to Section 23, Technology Access Control of the ICT Policy and Procedure document.
- 7.5.2 Users are required to maintain their own passwords, they should be provided initially with a unique secure temporary password which they are forced to change on first use.
- 7.5.3 Procedures should be established to verify the identity of a user prior to providing new, replacement or temporary password information.
- 7.5.4 Default vendor secret authentication information should be altered following installation of systems or software.
- 7.5.5 Initial temporary passwords must be conveyed in a secure manner.
- 7.5.6 All master login details for servers and network equipment should be aggregated into one secure location for ease of continuity in the event

of absence / unreachable of the technical staff that manages the login credentials.

7.6 USER AUTHENTICATION RESPONSIBILITY

- 7.6.1 Keep secret authentication information confidential, ensuring that it is not divulged to any other parties, including people of authority.
- 7.6.2 All users should abide to the password policy.
- 7.6.3 Avoid keeping a record (e.g. on paper, software file) of secret authentication information, unless this can be stored securely and the method of storing has been approved (e.g. Password manager, encrypted file)
- 7.6.4 Change password and secret authentication information whenever there is any indication of its possible compromise.
- 7.6.5 Do not share your individual password and other secret authentication information.
- 7.6.6 Do not use the same password for business and non-business purposes.

8 SYSTEM AND APPLICATION ACCESS CONTROL

8.1 SECURE LOG ON PROCEDURES

- 8.1.1 Access to all Agency systems and applications should be controlled by a secure log-on procedure.
- 8.1.2 Where strong authentication and identity verification is required, authentication methods alternative to passwords, such as cryptographic means, smart cards, tokens or biometric means, is recommended to be used.
- 8.1.3 Login banners and disclaimers must be used to remind users of their obligations when using NSA information systems.
- 8.1.4 All Agency sign on procedures should be protected against brute force log-on attempts.
- 8.1.5 All Agency passwords to be transmitted over a network should be encrypted and not be in plain text.
- 8.1.6 All NSA information systems must be able to terminate inactive sessions after a defined period of inactivity on all Agency systems and applications.

8.2 USE OF PRIVILEGED UTILITY PROGRAMS

- 8.2.1 The use of utility programs that might be capable of overriding system and application controls should be restricted and tightly controlled.

8.3 ACCESS CONTROL TO PROGRAM SOURCE CODE

- 8.3.1 Access to program source code and associated items should be strictly controlled, in order to prevent the introduction of unauthorized functionality.
- 8.3.2 The updating of program source libraries and associated items and the issuing of program sources to programmers should only be performed after appropriate authorization has been received.

- 8.3.3 Maintenance and copying of program source libraries should be subject to strict change control procedures.
- 8.3.4 An audit log should be maintained of all accesses to program source libraries.

9 CRYPTOGRAPHY

9.1 CRYPTOGRAPHIC CONTROLS

- 9.1.1 A procedure on the use of cryptographic controls for protection of information shall be developed and implemented.
- 9.1.2 A policy on the use, protection and lifetime of cryptographic keys shall be developed and implemented through their whole lifecycle.

10 PHYSICAL AND ENVIRONMENTAL SECURITY

10.1 PHYSICAL SECURITY PERIMETER

- 10.1.1 Security perimeters shall be defined and used to protect areas that contain either sensitive or critical information or information processing facilities.
- 10.1.2 All server rooms or information and storage processing facilities should be well protected with solid construction walls and roofs, an alarm system, door lock and tested water and fire suppression system.
- 10.1.3 Access to the server rooms and information and storage processing areas should be restricted to authorized personnel only.
- 10.1.4 All fire combating measures implemented should operate in accordance with local fire codes and international standards.
- 10.1.5 Suitable intruder detection systems should be installed to national, regional or international standards and regularly tested to cover all external doors and accessible windows.

10.2 PHYSICAL ENTRY CONTROLS

- 10.2.1 The date and time of entry and departure of visitors should be recorded, and all visitors should be supervised; they should only be granted access for specific, authorized purposes and should be issued with instructions on the security requirements of the area.
- 10.2.2 Access to areas where confidential information is processed or stored should be restricted to authorized individuals only by implementing appropriate access controls.
- 10.2.3 The identity of visitors should be authenticated by appropriate means.
- 10.2.4 Cleaning of the server room and information and storage processing facilities should always be supervised.
- 10.2.5 A physical log book or electronic audit trail of all access to the server room or information and storage processing facilities should be securely maintained and monitored.
- 10.2.6 External party support service personnel should be granted restricted access to secure areas or confidential information processing facilities only when required; this access should be authorized and monitored.

- 10.2.7 All employees, contractors and external parties should be required to wear some form of visible identification and should immediately notify security personnel if they encounter unescorted visitors and anyone not wearing visible identification.
- 10.2.8 Access rights to secure areas should be regularly reviewed and updated, and revoked when necessary

10.3 SECURING FACILITIES

- 10.3.1 Where applicable, buildings should be unobtrusive and give minimum indication of their purpose.
- 10.3.2 Facilities should be configured to prevent confidential information or activities from being visible and audible from the outside.
- 10.3.3 Physical protection against natural disasters, malicious attack or accidents should be designed and applied.

10.4 WORKING IN SECURE AREAS

- 10.4.1 Personnel should only be aware of the existence of, or activities within, a secure area on a need-to-know basis.
- 10.4.2 Photographic, video, audio or other recording equipment, such as cameras in mobile devices, should not be allowed, unless authorized.

10.5 DELIVERY AND LOADING AREAS

- 10.5.1 Incoming material should be inspected and examined for explosives, chemicals or other hazardous materials, before it is moved from delivery and loading area.
- 10.5.2 Incoming material should be inspected for evidence of tampering. If tampering is discovered it should be reported to security personnel.

10.6 SUPPORTING UTILITIES

- 10.6.1 Equipment should be protected from power failures and other disruptions caused by failures in supporting facilities.

10.7 CABLING SECURITY

- 10.7.1 Power and telecommunication cabling carrying data or supporting information services should be protected from interception, interference or damage.
- 10.7.2 There should be controlled access to patch panels and cable rooms.
- 10.7.3 Routine technical sweeps and physical inspections for unauthorized devices being attached to cables and patch panels.

10.8 EQUIPMENT MAINTENANCE

- 10.8.1 Equipment should be correctly maintained to ensure its continued availability and integrity.
- 10.8.2 Only authorized maintenance personnel should carry out repairs and service equipment.

- 10.8.3 Appropriate controls should be implemented when equipment is scheduled for maintenance, taking into account whether this maintenance is performed by personnel on site or external to the organization; where necessary, confidential information should be cleared from the equipment or the maintenance personnel should be sufficiently cleared.
- 10.8.4 All maintenance requirements imposed by insurance policies should be complied with.
- 10.8.5 Before putting equipment back into operation after its maintenance, it should be inspected to ensure that the equipment has not been tampered with and does not malfunction.

10.9 REMOVAL OF ASSETS

- 10.9.1 Equipment, information or software should not be taken off-site without prior authorization.
- 10.9.2 Where necessary and appropriate, assets should be recorded as being removed off-site and recorded when returned.

10.10 SECURITY OF EQUIPMENT AND ASSETS OFF-PREMISES

- 10.10.1 Security should be applied to offsite assets taking into account the different risks of working outside the organizations premises.
- 10.10.2 Equipment and media taken off premises should not be left unattended in public places.
- 10.10.3 When off premises equipment is transferred among different individuals or external parties, a log should be maintained that defines the chain of custody.

10.11 CLEAR DESK AND CLEAR SCREEN POLICY

- 10.11.1 Sensitive or critical business information, e.g. on paper or electronic storage media, should be locked away when not required, especially when the office is vacated.
- 10.11.2 Unauthorized use of photocopiers and other reproduction technologies should be prevented.
- 10.11.3 Media containing sensitive or classified information should be removed from printers immediately.
- 10.11.4 All printer should utilize private print functionality protected by a password or pin.

11 OPERATIONS SECURITY

11.1 DOCUMENTED OPERATING PROCEDURES

- 11.1.1 Operating procedures shall be documented and made available to all users who need them.

11.2 CHANGE MANAGEMENT

- 11.2.1 Changes to the organization, business processes, information processing facilities and systems that affect information security shall be controlled and updated accordingly.

11.3 SEPARATION OF DEVELOPMENT, TESTING AND OPERATIONAL ENVIRONMENTS

- 11.3.1 Development, testing, and operational environments shall be separated to reduce the risks of unauthorized access or changes to the operational environments.
- 11.3.2 Rules for the transfer of software from development to operational status should be defined and documented.
- 11.3.3 Changes to operational systems and applications should be tested in a testing or staging environment prior to being applied to operational systems.
- 11.3.4 Compilers, editors and other development tools or system utilities should not be accessible from operational systems when not required.
- 11.3.5 Sensitive data should not be copied into the testing system environment unless equivalent controls are provided for the testing system.

11.4 PROTECTION FROM MALWARE

- 11.4.1 Detection, prevention and recovery controls to protect against malware shall be implemented, combined with appropriate user awareness.
- 11.4.2 The use of unauthorized software is prohibited. The Agency must implement application whitelisting, specifying an index of approved software applications or executable files that are permitted to be present and active on a computer system.
- 11.4.3 The installation or configuration of software or applications on all Agency devices is strictly reserved for authorized IT Technicians and System specialists only, unless otherwise exempted by the Statistician-General through the Executive: IT & Data Processing.
- 11.4.4 The Agency shall establish a formal policy to protect against risks with obtaining files and software either from or via external networks or any other medium, indicating what protective measures should be taken.
- 11.4.5 Reduce vulnerability that could be exploited by malware through technical vulnerability management.
- 11.4.6 The Agency shall conduct regular reviews of the software and data content of systems supporting critical business process; the presence of any unapproved files or authorized amendments should be formally investigated.
- 11.4.7 The Agency must install and regularly update malware detection and repair software to scan devices, systems and media.
- 11.4.8 The anti-malware software used by the Agency must be able to scan files for malware before use.
- 11.4.9 The anti-malware software used by the Agency must be able to scan electronic mail attachments and downloads for malware before use.

- 11.4.10 The anti-malware software used by the Agency must be able scan web pages for malware.
- 11.4.11 The Agency must prepare appropriate business continuity plans for recovering from malware attacks, including all necessary data and software backup and recovery arrangements.
- 11.4.12 The Agency shall implement procedures to regularly collect information, such as subscribing to mailing lists or verifying websites giving information about malware.

11.5 BACKUPS

- 11.5.1 Backup copies of information, software and system images shall be taken and tested regularly in accordance with an agreed backup procedures or guideline.
- 11.5.2 A backup procedure or guideline should be established to define the Agency's requirement for backup of information, software and systems.
- 11.5.3 Adequate backup facilities should be provided to ensure that all essential information and software can be recovered following a disaster or media failure.
- 11.5.4 Operational procedures should monitor the execution of backups and address failures of scheduled backups to ensure completeness of backups according to the backup procedure or guideline.

11.6 LOGGING AND MONITORING

- 11.6.1 Event logs recording user activities, exceptions, faults and information security events shall be produced, kept and regularly reviewed.
- 11.6.2 Logging facilities and log information shall be protected against tampering and unauthorized access.
- 11.6.3 Sign in events for all systems must be logged, protected and reviewed.
- 11.6.4 System administrator and system operator activities shall be logged and the logs protected and regularly reviewed.

11.7 INSTALLATION OF SOFTWARE ON OPERATIONAL SYSTEMS

- 11.7.1 The updating of operational software, applications and program libraries should only be performed by IT specialists / administrators upon appropriate management authorization.
- 11.7.2 Operational systems should only hold approved executable code and not development code or compilers.
- 11.7.3 Applications and operating system software should only be implemented after extensive usability, security testing on a separate system.
- 11.7.4 A rollback strategy should be in place before changes are implemented.
- 11.7.5 An audit log should be maintained of all updates to operational program libraries.
- 11.7.6 Vendor supplied software used in operational systems should be maintained at a level supported by the supplier. Over time, software vendors will cease to support older versions of software. The Agency should consider the risks of relying on unsupported software.

- 11.7.7 Software patches should be applied when they can help to remove or reduce information security weaknesses.

11.8 MANAGEMENT OF TECHNICAL VULNERABILITIES

- 11.8.1 The NSA should define and establish the roles and responsibilities associated with technical vulnerability management, including vulnerability monitoring, vulnerability risk assessment, patching, asset tracking and any coordination responsibilities required.
- 11.8.2 Once a potential technical vulnerability has been identified, the organization should identify the associated risks and the actions to be taken; such action could involve patching of vulnerable systems or applying other controls.
- 11.8.3 If a patch is available from a legitimate source, the risks associated with installing the patch should be assessed (the risks posed by the vulnerability should be compared with the risk of installing the patch).
- 11.8.4 Patches should be tested and evaluated before they are installed to ensure they are effective and do not result in side effects that cannot be tolerated or tamper with systems and business operations. If no patch is available, other controls should be considered, such as:
- a. Turning off services or capabilities related to the vulnerability.
 - b. Adapting or adding access controls, e.g. firewalls, at network borders.
 - c. Increased monitoring to detect actual attacks.
 - d. Raising awareness of the vulnerability.
- 11.8.5 The technical vulnerability management process should be regularly monitored and evaluated in order to ensure its effectiveness and efficiency.
- 11.8.6 Systems at high risk should be addressed first.
- 11.8.7 An effective technical vulnerability management process should be aligned with incident management activities, to communicate data on vulnerabilities to the incident response function and provide technical procedures to be carried out should an incident occur.
- 11.8.8 Procedure to address the situation where a vulnerability has been identified but there is no suitable countermeasure. In this situation, the organization should evaluate risks relating to the known vulnerability and define appropriate detective and corrective actions.

11.9 INFORMATION SYSTEMS AUDIT CONTROLS

- 11.9.1 Audit requirements and activities involving verification of operational systems shall be carefully planned and agreed to minimize disruptions to business processes and activities.

12 COMMUNICATIONS SECURITY

12.1 NETWORK CONTROLS

- 12.1.1 Networks shall be managed and controlled to protect information in systems and applications.

- 12.1.2 Security mechanisms, service levels and management requirements of all network services shall be identified and included in network service agreements, whether these services are provided in-house or outsourced.
- 12.1.3 Appropriate logging and monitoring should be applied to enable recording and detection of actions that may affect, or are relevant to, information security.
- 12.1.4 All systems on the network should be authenticated.
- 12.1.5 Groups of information services, users and information systems shall be segregated on networks.
- 12.1.6 Special controls should be established to safeguard the confidentiality and integrity of data passing over public networks or over wireless networks and to protect the connected systems and applications special controls may also be required to maintain the availability of the network services and computers connected.

12.2 INFORMATION TRANSFER

- 12.2.1 Formal transfer policies, procedures and controls shall be in place to protect the transfer of information and data through the use of all types of communication facilities.
- 12.2.2 Agreements shall address the secure transfer of business information between the organization and external parties.
- 12.2.3 Information involved in electronic messaging shall be appropriately protected.
- 12.2.4 Requirements for confidentiality or non-disclosure agreements reflecting the organization's needs for the protection of information shall be identified, regularly reviewed and documented.

13 SYSTEMS ACQUISITION, DEVELOPMENT AND MAINTENANCE

13.1 SECURITY REQUIREMENTS OF INFORMATION SYSTEMS

- 13.1.1 All systems to be acquired through the Executive: IT & Data Processing or and Manager: IT respectively. To ensure that all specification are in line with the relevant policies, laws and internationally recommended best practices.
- 13.1.2 The information security related requirements shall be included in the requirements for new information systems or enhancements to existing information systems.
- 13.1.3 Information and data involved in application services passing over public networks shall be protected from fraudulent activity, contract disputes and unauthorized disclosure and modification.
- 13.1.4 Information involved in application service transaction shall be protected to prevent incomplete transmission, mis-routing, unauthorized message alteration, unauthorized disclosure, unauthorized message duplication or replay.

13.2 SECURITY IN DEVELOPMENT AND SUPPORT PROCESSES

- 13.2.1 Rules for the development of software and systems shall be established and applied to development projects within the organization.
- 13.2.2 Changes to systems within the development lifecycle shall be controlled by the use of formal change control procedures.
- 13.2.3 When operating platforms are changed, business critical applications shall be reviewed and tested to ensure there is no adverse impact on organizational operations and security.
- 13.2.4 Modifications to software packages shall be discouraged, limited to necessary changes and all changes shall be strictly controlled.
- 13.2.5 Principles for engineering secure systems shall be established, documented, maintained and applied to any information systems implementation efforts.
- 13.2.6 The Agency shall establish and appropriately protect secure development environments for system development and integration efforts that cover the entire system development lifecycle.
- 13.2.7 The Agency shall supervise and monitor the activity of outsourced system development.
- 13.2.8 Testing of security functionality shall be carried out during development.
- 13.2.9 Acceptance testing programs and related criteria shall be established for new information systems, upgrades and new version.

13.3 TEST DATA

- 13.3.1 Data used to test systems shall be selected carefully, protected and controlled.

14 SUPPLIER RELATIONSHIP

14.1 INFORMATION SECURITY IN RELATION TO SUPPLIERS

- 14.1.1 Information security requirements for mitigating the risks associated with supplier's access to the organization's assets shall be agreed with the supplier and documented.
- 14.1.2 All relevant information security requirements shall be established and agreed with each supplier that may access, process, store, communicate, or provide IT infrastructure components for, the Agency's information.
- 14.1.3 Agreements with suppliers shall include requirements to address the information security risks associated with information and communication technology services and product supply chain.

15 INFORMATION SECURITY INCIDENT MANAGEMENT

15.1 RESPONSIBILITIES AND PROCEDURES

- 15.1.1 Responsibilities and procedures shall be established to ensure a quick, effective and orderly response to information security incidents.
- 15.1.2 Management responsibilities should be established to ensure that the following procedures are developed and communicated adequately within the NSA.
 - a. Procedures for incident response planning and preparation.

- b. Procedures for monitoring, detecting, analysing and reporting of information security events and incidents.
- c. Procedures for logging incident management activities.
- d. Procedures for handling of forensic evidence.
- e. Procedures for assessment of and decision on information security events and assessment of information security weaknesses.
- f. Procedures for response including those for escalation, controlled recovery from an incident and communication to internal and external people or organizations.

15.1.3 Procedures established should ensure that:

- a. Competent personnel handle the issues related to information security incidents within the organization.
- b. A point of contact for security incidents' detection and reporting is implemented.
- c. Appropriate contacts with authorities, external interest groups or forums that handle the issues related to information security incidents are maintained.

15.1.4 Reporting procedures should include

- a. Preparing information security event reporting forms to support the reporting action and to help the person reporting to remember all necessary actions in case of an information security event.
- b. The procedure to be undertaken in case of an information security event, e.g. noting all details immediately, such as type of non-compliance or breach, occurring malfunction, messages on the screen and immediately reporting to the point of contact and taking only coordinated actions.
- c. Reference shall be made to the NSA Disciplinary Policy established formal disciplinary process for dealing with employees who commit security breaches.
- d. Suitable feedback processes to ensure that those persons reporting information security events are notified of results after the issue has been dealt with and closed.

15.2 REPORTING INFORMATION SECURITY EVENTS

- 15.2.1 Information security incidents shall be reported through appropriate management channels as quickly as possible.
- 15.2.2 All employees and contractors should be aware of the procedure for reporting information security events and the point of contact to which the events should be reported.

15.3 REPORTING INFORMATION SECURITY WEAKNESSES

- 15.3.1 Employees and contractors using the NSA's information systems and services shall be required to note and report any observed or suspected information security weaknesses in systems or services.
- 15.3.2 Employees and contractors should be advised not to attempt to prove suspected security weaknesses. Testing weaknesses might be

interpreted as a potential misuse of the system and could also cause damage to the information system or service and result in legal liability for the individual performing the testing.

15.4 ASSESMENT OF AND DECISION ON INFORMATION SECURITY EVENTS

- 15.4.1 Information security events shall be assessed and it shall be decided if they are to be classified as information security incidents or not.
- 15.4.2 Results of the assessment and decision should be recorded in detail for the purpose of future reference and verification.
- 15.4.3 Information security incidents shall be responded to in accordance with the documented procedures.
- 15.4.4 Knowledge gained from analyzing and resolving information security incidents shall be used to reduce the likelihood or impact of future incidents.
- 15.4.5 The first goal of incident response is to resume 'normal security level' and then initiate the necessary recovery.
- 15.4.6 Post-incident analysis should take place, as necessary, to identify the source of the incident.

15.5 COLLECTION OF EVIDENCE

- 15.5.1 The NSA shall define and apply procedures for the identification, collection, acquisition and preservation of information, which can serve as evidence.
- 15.5.2 Internal procedures in line with the NSA Disciplinary Policy should be followed when dealing with evidence for the purposes of disciplinary and legal action.

16 INFORMATION SECURITY ASPECTS OF BUSINESS CONTINUITY MANAGEMENT

16.1 INFORMATION SECURITY CONTINUITY

- 16.1.1 The NSA shall determine its requirements for information security and the continuity of information security management in adverse situations, e.g. during a crisis or disaster.
- 16.1.2 The NSA shall establish, document, implement and maintain processes, procedures and controls to ensure the required level of continuity for information security during an adverse situation.
- 16.1.3 The NSA shall verify the established and implemented information security continuity controls at regular intervals in order to ensure that they are valid and effective during adverse situations.

16.2 REDUNDANCIES

- 16.2.1 Information processing facilities shall be implemented with redundancy sufficient to meet availability requirements.

17 COMPLIANCE

17.1 COMPLIANCE WITH LEGAL AND CONTRACTUAL REQUIREMENTS

- 17.1.1 All relevant legislative statutory, regulatory, contractual requirements and the NSA's approach to meet these requirements shall be explicitly identified, documented and kept up to date for each information system at the NSA.
- 17.1.2 Appropriate procedures shall be implemented to ensure compliance with legislative, regulatory and contractual requirements related to intellectual property rights and use of proprietary software products.
- 17.1.3 Records shall be protected from loss, destruction, falsification, unauthorized access and unauthorized release, in accordance with legislator, regulatory, contractual and business requirements.
- 17.1.4 Privacy and protection of personally identifiable information shall be ensured as required in relevant legislation and regulation where applicable.
- 17.1.5 Cryptographic controls shall be used in compliance with all relevant agreements, legislation and regulations.

17.2 INFORMATION SECURITY

- 17.2.1 The Agency's approach to managing information security and its implementation (i.e. control objectives, controls, policies, processes and procedures for information security) shall be reviewed independently at planned intervals or when significant changes occur.
- 17.2.2 Managers shall regularly review the compliance of information processing and procedures within their area of responsibility with appropriate security policies standards and any other security requirements.
- 17.2.3 Information systems shall be regularly reviewed for compliance with the organization's information security policies and standard

APPENDIX I – USER STATEMENT

Statement on being acquainted with the Information Security And Data Protection Policy

I, the undersigned (*Full name*) _____

ID Number _____

Hereby declare that:

I have received a copy of the following Information Security and Data Protection Policy

I have read the documents in full, and I understand all their provisions and their meaning and that I am bound to respect all the provisions stated therein, - I am aware that breach of the information security and data protection policy and the rules constitutes basis for disciplinary action determined by these rules, other internal policies of NSA and the legislation or laws of the Republic of Namibia.

Signed at _____, on _____

Signature: _____

 TS